汽车零部件理论计算平台 安全与维护准备条例

版本：V1.0　**适用版本**：0.1.0 及后续版本　**生效日期**：2026-11-03

第一章 总则

第一条（目的） 为保障「汽车零部件理论计算平台」（以下简称"本软件"）的计算准确性、数据安全性与可持续维护性，规范开发、发布、使用与维护各环节的安全准备与操作要求，特制定本条例。

第二条（适用范围） 本条例适用于本软件的全部开发人员、维护人员、分发管理人员及终端使用人员（设计/CAE 工程师）。

第三条（软件构成） 本软件为 Electron 桌面应用（React 18 + TypeScript + Vite，Windows 平台 NSIS 安装包），核心功能为汽车零部件理论公式计算、计算书（Word/PDF/CSV）导出、历史方案管理与知识库查阅。计算依据文档统一存放于仓库 `公式梳理/` 目录。

第二章 账户与访问安全

第四条（密码安全）

1. 用户密码一律以 bcrypt 哈希存储，严禁以明文或可逆形式记录、传输、展示密码。
2. 严禁在代码、注释、配置文件、测试数据、提交信息中写入任何真实口令、密钥或个人敏感信息。
3. 默认/初始账户仅限首次部署调试使用，正式交付前必须修改默认口令。

第五条（数据访问）

1. 本软件数据默认保存在用户本机，使用者应确保登录账号为本机授权人员。
2. 导出的计算书、CSV 数据文件含工程设计参数，应按公司内部资料保密要求存放与外发，不得通过个人网盘、公共邮箱外传。
3. 删除历史方案、项目数据为不可恢复操作，执行前须确认；系统应保留 `backup/` 目录自动备份机制。

第三章 发布与分发安全

第六条（安装包管理）

1. 安装包统一由 `npm run build` 产出，存放于 `release/` 目录，当前为未签名包；分发前须向接收方明示"未签名"状态及安装时的系统提示属正常现象。
2. 每次分发须记录：安装包文件名、大小、生成时间、对应 git 提交号，并计算 SHA-256 哈希随包提供，接收方校验一致后方可安装。
3. 严禁通过非授权渠道（个人 U 盘转借、外部链接）分发安装包；`release/` 目录文件不得手动改名后分发。

第七条（版本与回滚）

1. 每个发布版本必须对应一条 git 提交；发布前确认 `git status` 工作区干净。
2. 保留最近 2 个版本安装包以备回滚；发现新版缺陷时，回退安装上一版本并向维护组报告。

第四章 计算准确性与公式验证

第八条（公式来源管理）

1. 所有计算公式的理论依据必须存档于 `公式梳理/` 目录（Word 文档），文档修订与代码修改须同一次提交，保证"代码—资料"同步。
2. 新增或修改公式时，必须同步补充基准算例（BenchmarkCase），基准值须经手算或文献算例核对，容差不大于 1e-9。

第九条（结果验证）

1. 每次代码修改后，发布前必须通过：`npx tsc --noEmit`（类型检查零错误）与 `npx vitest run`（全部基准测试通过，当前基线 73 项）。任何一项不通过不得发布。
2. 既有基准算例数值不得随新功能改变；确需调整基准时，须在提交信息中说明原因并经复核。
3. 工程使用中，本软件计算结果为理论估算值，定型设计仍须以台架试验（如 ISO 5011）标定为准；公式中标注"未经试验标定仅供参考"的模块（如多腔消音器 R0）不得直接用于产品定型。

第五章 开发与代码维护

第十条（提交规范）

1. 提交信息采用约定式格式：`feat(域): 说明` / `fix(域): 说明` / `style: 说明`，域包括 `fluid`、`acoustics`、`structure` 等；一次提交只做一类变更。
2. 禁止提交：临时脚本、调试文件（`.tmp/`、`.screenshots/` 等）、本地缓存；合并前确认 `git status --short` 仅含预期文件。
3. 不得在提交中夹带 `.env`、证书、私钥等敏感文件；发现误提交立即上报并按敏感信息泄露流程处理（重写历史 + 更换密钥）。

第十一条（代码质量红线）

1. 公式名称保持简洁，不含括号说明内容（永久规则）。
2. 输出结果统一保留 3 位小数（`digits: 3`），新增输出项不得例外。
3. 单位换算一律经 `src/formula/units.ts` 单位分组完成，solve 函数只处理 SI 值；禁止在公式内手写单位换算系数。
4. 条件显隐统一使用 `showIf` 声明式实现，禁止在组件层硬编码参数显隐逻辑。

第十二条（依赖与漏洞管理）

1. 每季度执行一次 `npm audit`，高危漏洞须在发现后一周内修复或评估豁免并记录。
2. 升级依赖（含 Electron、Vite、React、KaTeX）前，必须全量回归：tsc + vitest + 打包 + 安装包启动冒烟验证。

3. 引入新依赖须评审必要性，优先使用已在清单中的库；禁止引入来源不明的包。

第六章 运行环境与维护周期

第十三条（运行环境）

1. 目标平台：Windows 10/11 64 位；开发环境：Node.js + PowerShell。
2. 终端使用机器应安装杀毒软件并保持系统补丁更新；安装包首次运行如出现 SmartScreen 提示（未签名所致），确认来源后方可继续。

第十四条（例行维护）

周期	事项	责任角色
每次发布	tsc + vitest 全量验证；记录提交号、哈希、包大小	开发/发布
每周	备份 `backup/` 与用户数据目录；检查磁盘空间	维护
每月	核对 `公式梳理/` 文档与代码公式条目一致性	维护/技术负责人
每季度	npm audit 漏洞扫描；依赖健康度评审	开发
每半年	回收最近 2 版以外旧安装包；复核用户账户有效性	维护

第十五条（缺陷与故障响应）

1. 计算结果异常类缺陷为最高优先级：先停用相关公式入口（或公告风险），再修复、补基准、回归后发布。
2. 崩溃/无法启动类故障：收集报错截图、软件版本号（git 提交号）、操作步骤，提交维护组；紧急时按第七条回滚版本。
3. 所有缺陷修复必须留有 git 记录，禁止无记录的"口头改包"。

第七章 知识传承与文档

第十六条 公式实现说明统一写在各公式文件头部注释（含公式编号与适用范围），重要设计决策写入项目记忆，确保新接手人员可凭"代码注释 + 公式梳理文档 + 基准算例"独立理解。

第十七条 本条例随软件版本演进修订，修订须注明版本号与日期，与代码同库存放、同流程评审。

附则

第十八条 本条例自发布之日起施行，由软件开发维护组负责解释。

第十九条 违反本条例造成数据泄露、错误计算结果用于产品定型等后果的，按公司相关规定追究责任。